



Cloud Security Posture Management

Exception Governance

Wiz CSPM – Deviation & Exception Management

Field	Details
Version	1.1
Owner	Cloud Security
Last Updated	May 2026
Review Cycle	Quarterly
Audience	Application Teams · Cloud Platform · Cloud Security · GRC
Scope	Wiz CSPM Controls, Policies, and Findings — all AWS environments
Intake (Current)	GitHub Issues → Vela Pipeline (temporary)
Intake (Future)	CargillNow / ServiceNow

Table of Contents

Table of Contents..... 1

1. Purpose..... 3

 1.1 Foundational Principle 3

2. Definitions 3

3. Scope 3

4. Deviation Types 4

5. Pre-Assessment Gate..... 4

6. Exception Process – Temporary Exceptions 4

 6.1 Build Exception vs. Runtime Exception 5

 6.2 Lifecycle 5

 6.3 Required Submission Fields 6

 6.4 Rejection & Remediation 6

 6.5 Renewal 6

 6.6 Expiry & Auto-Revocation 7

7. Design-Approved Exemptions & Risk Accepted 7

7.1 Design-Approved Exemptions	7
7.2 Risk Accepted	7
8. False Positive / Not Applicable	8
9. Risk Scoring.....	8
9.1 Scoring Dimensions	8
9.2 Approval Tiers	9
9.3 Deviation Type SLA Reference	9
10. Terraform Implementation	9
10.1 Exception Resource	9
10.2 Design Exemption Resource	10
10.3 IaC PR Gate — Required Checks	11
11. Monitoring, Drift & Revocation.....	11
12. Notifications	11
13. Audit & Compliance Evidence	12
14. Future State – CargillNow	12
15. References.....	12

1. Purpose

This document defines the governed process for handling deviations from Wiz CSPM controls and findings across all Cargill AWS environments. Every deviation must be intentional, approved, time-bound where applicable, and fully auditable.

The objectives are to:

- Enable engineering agility without compromising security posture
- Ensure all deviations are visible, approved, and traceable
- Provide teams with a clear, repeatable process from identification to closure

1.1 Foundational Principle

If something is permanent, it is NOT an exception. Exceptions are temporary. Architectural decisions that intentionally deviate from a control are Design-Approved Exemptions — a separate, heavier governance path.

Goal: "Green at all costs" and undocumented risk are equally unacceptable. Every deviation is a decision — own it, document it, time-bound it.

2. Definitions

Term	Definition
Exception	Temporary, time-bound deviation. Maximum 180 days. Requires expiry and renewal.
Design-Approved Exemption	Permanent deviation based on approved architectural intent. No expiry — but mandatory periodic revalidation.
Risk Accepted	Long-term or permanent acceptance of known risk. Requires Manager sign-off and annual review. Heaviest governance path.
False Positive / N/A	Control does not apply to this resource due to context. Lightweight approval path.
Ignore Rule	Wiz policy object (wiz_ignore_rule) that suppresses a finding. Managed via Terraform → Vela pipeline.
Vela Pipeline	IaC deployment pipeline. All exception Terraform resources are deployed here.
Intake Process	Current: GitHub Issues at git.cglcloud.com/CloudSecurity/cs-team-collaborations/issues . Future: CargillNow.

3. Scope

Applies to all Wiz CSPM controls, policies, and resource-level findings across production and non-production AWS environments.

 Manual suppression of findings outside this governed process is not permitted.

4. Deviation Types

Type	Description	Duration	Process
Exception	Temporary deviation with expiry	Max 180 days	→ Section 6
Design-Approved Exemption	Permanent architectural decision	No expiry — revalidated annually	→ Section 7
Risk Accepted	Permanent / long-term risk acceptance	Annual review · Manager sign-off	→ Section 7
False Positive / N/A	Control does not apply	Lightweight path	→ Section 8

5. Pre-Assessment Gate

Before any exceptions are filed, Cloud Security and Security Architecture jointly perform a one-time framework review of all CSPM controls. This is not a per-exception step — it is a periodic governance gate that runs at framework onboarding and quarterly thereafter.

Activity	Description	Timing
What happens	Cloud Security + Security Architecture review all controls to confirm they are valid, necessary, and appropriate for Cargill's environment	Periodic — not per exception
Output	Controls identified as inapplicable, duplicative, or misconfigured are removed or scoped before the exception process begins	Before exceptions open
Why it matters	Prevents teams from filing exceptions for controls that should never have applied in the first place	Reduces exception volume

 This gate reduces noise. If a control is wrong for the platform, fix the control — don't build an exception library on top of a bad baseline.

6. Exception Process – Temporary Exceptions

⌚ Current intake: GitHub Issues (temporary)

Exceptions are submitted via GitHub [Issues](#). Once CargillNow is ready, submission moves there — the approval, implementation, and expiry steps remain unchanged. See Section 12 for the full future state.

6.1 Build Exception vs. Runtime Exception

Before submitting, identify where the violation was detected — this determines the urgency and context of the exception request.

Type	Where it's caught	What it means
Build exception	Caught by Wiz CI/CD scanner at IaC / deploy stage — before the resource exists in the environment	Lower urgency. Resource not yet deployed. Exception applied before deployment to prevent a violation from reaching production.
Runtime exception	Detected in a live, deployed resource via Wiz findings	Higher urgency. Resource is already running with the misconfiguration. Exception applied to the live environment while remediation is planned.

✓ Both paths converge at the submission process and approval workflow are identical regardless of where the violation was detected.

6.2 Lifecycle

1. **Framework pre-assessment** — Cloud Security + Security Architecture confirm controls are valid before exceptions begin.
2. **Finding identified** — application team reviews controls against their resource context. SLA: 2 business days to identify and classify.
3. **Submit exception** — app owner submits a GitHub Issue (current) or CargillNow ticket (future) with all required fields (Section 6.3). SLA: 2 business days after finding.
4. **Technical review** — Cloud Security validates resource details and confirms the control applies. SLA: 2 business days.
5. **Finding review** — Security Architecture reviews the exception in context, validates the justification and deviation type. SLA: 2 business days.
6. **Risk assessment** — Cloud Security + Security Architecture jointly score the exception (see Section 9). Approval path determined by score. SLA: 3 business days.
7. **Approved → implement** — Cloud Security deploys the `wiz_ignore_rule` via Vela pipeline. PR linked to ticket. Wiz scan must pass. SLA: 2 business days.
8. **Expiry enforcement** — automated T-30 warning, T-7 manager escalation, T+0 auto-revocation (Section 6.6).

6.3 Required Submission Fields

Field	Description	Status
Exception ID	Auto-generated from GitHub Issue / CargillNow ticket number	Auto-generated
Wiz Control / Rule ID	The control being excepted (e.g. S3-041)	Required
Wiz Rule UUID	Internal Wiz rule UUID	Required
AWS Account & Region	Account ID and region of affected resource	Required
Resource Scope	Specific resource, account, or subscription	Required
Deviation Type	Exception / Design-Approved / Risk Accepted / False Positive	Required
Business Justification	Why remediation is not feasible	Required
Risk Description	Risk accepted if exception is granted	Required
Compensating Controls	Controls already in place to mitigate the risk	Required
Business Owner	Name and team	Required
Requested Expiry Date	Max 180 days from submission	Required
Renewal Required	Yes / No	Required
Ticket / Change Reference	Associated ITSM or change reference (e.g. ADC-123)	Required

6.4 Rejection & Remediation

If an exception is rejected, the owner receives a rejection notice with a reason code and three options: fix the misconfiguration and close, resubmit with a stronger justification, or escalate to a Manager for risk acceptance review.

If no response is received within 5 business days, the Manager is automatically notified and the resource is flagged as non-compliant in Wiz until resolved.

 Exceptions cannot be self-approved. An application team may not approve their own request under any circumstances.

6.5 Renewal

Exceptions do not renew automatically. The owner is notified at T-30 days and again at T-7 days. To renew, submit a new issue referencing the original exception ID with an updated justification. Renewal follows the same approval process as a new exception.

6.6 Expiry & Auto-Revocation

Trigger	Action	Outcome
T-30 days	ServiceNow / email notifies resource owner and app owner	Owner prompted to initiate renewal or close if no longer needed
T-7 days	Manager auto-added to ticket if no renewal action taken	Exception flagged as 'expiring — no action'
T+0	Wiz ignore policy automatically removed via Vela pipeline	Resource re-enters findings queue · ticket closed as expired
Renewal	Owner triggers renewal before T+0	Re-enters workflow at Step 3 with prior history included

 Manual extension of the expired_at field without going through the approval process is not permitted.

7. Design-Approved Exemptions & Risk Accepted

7.1 Design-Approved Exemptions

Used when a control conflicts with intentional, approved architectural decisions. Permanent — no expiry. Subject to mandatory annual revalidation.

Category	Examples
Valid reasons	Managed cloud service behaviour · Platform-level shared services · Required public endpoints behind WAF/CDN · Vendor-controlled configurations · Control intent met via alternate mechanism
Not valid	Convenience · Delivery speed · Avoiding remediation effort · Temporary technical debt · Known insecure implementations

Role	Responsibility
Approvers	Security Architecture (primary) + Cloud Security — both mandatory
GRC / Risk	Visibility only
Revalidation	Minimum annually — mandatory

7.2 Risk Accepted

Used when a known risk is intentionally accepted for the long term. This is the heaviest governance path — reserved for situations where neither remediation nor a design exemption is appropriate.

Requirement	Detail
Approvers	Security Architecture + Cloud Security + Manager sign-off — all mandatory
Duration	No fixed expiry — mandatory annual review
Risk score gate	Score ≥ 70 always escalates to Manager regardless of other factors
Annual review	Risk acceptance must be reaffirmed annually with updated justification

8. False Positive / Not Applicable

Type	Description
False Positive	Wiz has incorrectly flagged a resource — the resource is actually compliant
Not Applicable	The control exists but does not apply to this resource type, platform, or use case

Submit a GitHub Issue / CargillNow ticket with justification and evidence. Cloud Security confirms the classification and implements a `wiz_ignore_rule` with `finding_ignore_reason = NOT_APPLICABLE` or `FALSE_POSITIVE`. Approvers: platform engineer + Cloud Security. Total SLA: 2 business days.

9. Risk Scoring

Cloud Security and Security Architecture jointly score every exception across five dimensions. The total score determines the approval path. For an interactive version of this calculator, refer to the governance HTML reference.

9.1 Scoring Dimensions

Dimension	Score	Guide
Exposure	0 – 25	0 = internal only · 25 = internet-facing, no controls
Data sensitivity	0 – 25	0 = public / non-sensitive · 25 = PII, regulated, or confidential
Identity blast radius	0 – 20	0 = single non-privileged user · 20 = admin or org-wide access

Attack path length	0 – 15	0 = no exploitable path · 15 = direct, no additional steps
Criticality / business impact	0 – 15	0 = non-critical dev · 15 = Tier-1 production system
[object Object]	[object Object]	Combined score gates the approval path

9.2 Approval Tiers

Score	Path	Approvers	SLA
0 – 29	Expedited	Cloud Security only	1 business day
30 – 69	Standard	Cloud Security + Security Architecture	3 business days
70 – 100	Manager escalation	Cloud Security + Security Architecture + Manager	10 business days

9.3 Deviation Type SLA Reference

Type	Approvers	Duration	Total SLA
Exception (time-limited)	Platform review + Risk score gate	Max 180 days	5 business days
Design-Approved Exemption	Platform review + Arch. Security + App owner	Permanent — annual revalidation	5 business days
Risk Accepted	Platform review + Risk score + Manager	Permanent — annual review	10 business days
False Positive / N/A	Platform engineer + Cloud Security	N/A	2 business days

10. Terraform Implementation

All exceptions are implemented as Terraform `wiz_ignore_rule` resources and deployed via the Vela pipeline. This ensures every deviation is version-controlled, peer-reviewed, and automatically revoked on expiry.

 **Temporary process:** GitHub Issues → auto-generated Terraform → Vela pipeline. Moves to CargillNow once available.

10.1 Exception Resource

```
# Auto-generated from GitHub Issue
# https://git.cglcloud.com/CloudSecurity/cs-team-collaborations/issues/10
# Control: S3-041
resource "wiz_ignore_rule" "gh_10_ignore" {
  name                = "S3 object lock exception - ADC-123"
  description          = "Exception: S3-041. GH-10. Ticket: ADC-123. Expires: 2026-07-30."
  enabled              = true
  finding_ignore_reason = "EXCEPTION"
  finding_types        = ["CLOUD_CONFIGURATION"]
  rule_lifecycle_targets = ["RUNTIME"]
  cloud_configuration_rules = ["dc8bb010-7ae4-4eec-b91e-4b20031bd610"]
  cloud_configuration_finding_conditions {
    severity = ["INFORMATIONAL", "LOW", "MEDIUM", "HIGH", "CRITICAL"]
  }
  expired_at = "2026-07-30T23:59:59Z"
  tags { key = "source" value = "dev-intake" }
  tags { key = "issue" value = "GH-10" }
  tags { key = "ticket" value = "ADC-123" }
}
```

10.2 Design Exemption Resource

```
# Design-Approved Exemption - no expiry - Security Architecture approved
resource "wiz_ignore_rule" "design_vpc033_icmp" {
  name                = "Platform ICMP - design exemption"
  description          = "Design exemption: VPC-033. Platform default. Revalidation: 2027-05-01."
  enabled              = true
  finding_ignore_reason = "NOT_APPLICABLE"
  finding_types        = ["CLOUD_CONFIGURATION"]
  rule_lifecycle_targets = ["RUNTIME"]
  cloud_configuration_rules = ["<VPC-033-RULE-UUID>"]
  cloud_configuration_finding_conditions {
    severity = ["INFORMATIONAL", "LOW", "MEDIUM", "HIGH", "CRITICAL"]
  }
  # No expired_at - permanent
  tags { key = "type" value = "design-exemption" }
  tags { key = "approved_by" value = "security-architecture" }
  tags { key = "revalidation_at" value = "2027-05-01" }
  tags { key = "ticket" value = "ADC-XXX" }
}
```

10.3 IaC PR Gate — Required Checks

Requirement	Detail
Branch naming	exception/CNOW-{ticket-id}-{deviation-type} or exception/GH-{issue-id}-{deviation-type}
PR description	Auto-includes: deviation type · risk score · approver names · expiry date
Wiz CI/CD scan	Must pass on PR diff — no new violations introduced
Reviewer	Minimum 1 — Cloud Security or Security Architecture
Ticket status	CargillNow / GitHub Issue must be in Approved state before merge
Expiry date	Must be present in IaC metadata — pre-merge hook blocks if missing
Audit trail	Merge commit SHA written back to ticket · all reviewer comments retained in Git

11. Monitoring, Drift & Revocation

Activity	Description
Exception register	Cloud Security maintains a live register of all active exceptions, expiry dates, and deviation types. Reviewed quarterly.
Wiz policy dashboard	All active ignore rules visible in Wiz. Reviewed quarterly.
Design exemption revalidation	Tracked against revalidation_at tag. Triggered 30 days before due date.
Drift detection	Terraform state is source of truth. Manual Wiz changes flagged as drift on next Vela run — triggers immediate re-review.
Metrics	Exception counts, approval rates, expiry rates, and renewal rates reported quarterly to GRC and Security Architecture.

● Unauthorised modifications to exception resources are treated as a policy violation and escalated to Cloud Security and GRC.

12. Notifications

Channel	Role	Triggers
---------	------	----------

CargillNow / ServiceNow (future)	Primary	All lifecycle events — created, approved, rejected, expiring, expired, renewed. System of record.
Email	Primary (current)	Key events via GitHub Actions / email during the temporary GitHub Issues phase. Approval, rejection, T-30, T-7 warnings.
Manager dashboard (future)	Supplementary	Real-time view of open exceptions by risk score, deviation type, and days-to-expiry. Auto-populated from CargillNow + Wiz API.

13. Audit & Compliance Evidence

Evidence	Description
Git history & Terraform PRs	All changes version-controlled with pull request approval records
GitHub Issue / CargillNow records	Submission, review, approval, and rejection records retained
Wiz ignore policy audit log	Creation, modification, and deletion events logged by Wiz
Exception register	All active and expired exceptions with full metadata
Revalidation evidence	Design exemption revalidation records with approver details and dates
Risk acceptance documentation	Signed risk acceptance records for all Risk Accepted deviations
Metrics & reporting	Quarterly reports to GRC and Security Architecture

14. Future State – CargillNow

 **The GitHub Issues intake process is temporary.** Once CargillNow is available, exception submission, approval workflow, and notifications move there. Terraform implementation and Vela pipeline deployment remain unchanged.

Step	Current (Temporary)	Future (CargillNow)
Exception submission	GitHub Issues	CargillNow form
Approval workflow	GitHub Issue comments + email	CargillNow workflow
Notifications	GitHub Actions / email	CargillNow + email
Audit record	GitHub Issue + Git history	CargillNow + Git history
Exception deployment	Vela pipeline (unchanged)	Vela pipeline (unchanged)

15. References

- [Wiz Ignore Policies Documentation](#)
- [Wiz Terraform Provider — wiz ignore rule](#)
- [GitHub Issues — cs-team-collaborations](#)
- [CSA CCM v4.0.5 Cargill Framework \(Wiz\)](#)
- [Cloud Security Navigator \(CSN\)](#)
- [Master Template – Remediation SOP](#)
- [CSPM Finding Management Tool](#)